

Staff Roles & Access Control Architecture (RBAC)

Security Protocol Specification • Version 2.4 (Production Live) • FCT Abuja & National Expansion

1. Executive Overview & Security Philosophy

HandyHub Pro Solutions enforces a strict Role-Based Access Control (RBAC) architecture designed on the Principle of Least Privilege. Administrative privileges are partitioned into 5 discrete functional tiers, ensuring operational agility while guaranteeing financial isolation, customer data privacy, and tamper-proof compliance audits.

2. Administrative Staff Roles & Responsibilities

Chief Commander

[ROLE: SUPER_ADMIN]

Supreme platform sovereignty. Complete unchecked authority over global system settings, dynamic commission percentages, database backups, staff promotions, API credentials, and administrative overrides.

Operations Manager

[ROLE: OPERATIONS_MANAGER]

Command of field dispatch, booking state lifecycles (Assigned, En Route, In Progress), artisan radius zones, active artisan reassignments, and operational dispute triage.

Verification Officer

[ROLE: VERIFICATION_OFFICER]

Responsible for trust, safety, and compliance. Audits the 5-pillar artisan dossier (NIN identity, live facial biometric selfie, trade competency certificate, residential utility bill, guarantors, trade quiz) and customer address proofs.

Customer Support Agent

[ROLE: CUSTOMER_SUPPORT]

Customer experience and issue mediation. Handles booking status tracking, customer inquiries, dispute ticket mediation, review moderation, and artisan performance triage.

Finance Administrator

[ROLE: FINANCE]

Oversees financial infrastructure. Audits Paystack/Monnify payment logs, manages the Escrow Vault (holding, release, customer refunds), reviews artisan bank withdrawal requests, and manages promo code budgets.

3. Granular Module Permissions Matrix

Dashboard Module / Permission	Super Admin	Operations	Verification	Support	Finance
KPI Command Center Telemetry (/dashboard)	Full	Full	Full	Full	Full
Live Map & Dispatch Radius (/map)	Full	Full	—	—	—
Bookings Workflow & Dispatch (/bookings)	Full	Full	—	Read/Triage	Audit
Users & Staff Role Directory (/users)	Full	View Users	—	View Users	—
Staff Hiring & Role Promotion	Authorized	—	—	—	—
Artisan Verification Dossiers (/professionals)	Full	View Only	Approve/Reject	View Only	—
Customer Address Proof Audits (/verification)	Full	—	Approve/Reject	—	—
Dispute & Refund Resolution (/disputes)	Full	Manage	—	Mediate	Refund Auth
Payments & Escrow Vault (/payments)	Full	—	—	—	Full Audit
Escrow Payout Releases & Refunds	Authorized	—	—	—	Authorized
Customer Reviews & Moderation (/reviews)	Full	Moderate	—	Moderate	—
Promo Codes Campaign Engine (/promo-codes)	Full	—	—	—	Manage
Analytics & Financial Export (/analytics)	Full	Ops Metrics	—	—	Rev Reports
Commission & Escrow Policy (/settings)	Authorized	—	—	—	—
Database Backups & System Purge	Authorized	—	—	—	—

4. Multi-Layer Enforcement Architecture

A. Dynamic Navigation Filtering (Frontend UI)

The Admin Layout Shell evaluates logged-in staff roles against `src/lib/rbac.ts`. Unauthorized dashboard modules and tools are completely omitted from the sidebar navigation menu.

B. Server-Side Route Guarding & API Authorization

Every backend endpoint (`/api/admin/*`) cryptographically inspects the requesting session and cookies. Direct URL manipulation returns HTTP 403 Forbidden with zero data exposure.

C. Immutable Audit Trail Logging

High-consequence actions (artisan verification, escrow payout releases, dispute refunds, staff promotion, and commission rule updates) write immutable records to the PostgreSQL AuditLog ledger with actor ID, timestamp, and metadata.

